Ejercicio practico

Solution Architect BP

Diseño de Arquitectura Empresarial

Arquitectura basada en principios de escalabilidad, resiliencia y desacoplamiento

Autor: Xavier Salazar P

Fecha: 2026

Versión: 1.0.0

Introducción

La presente propuesta describe la arquitectura de solución para una plataforma de banca digital orientada a clientes que requieren consultar sus movimientos, realizar transferencias entre cuentas propias e interbancarias, recibir notificaciones sobre sus operaciones y completar procesos de autenticación y onboarding digital de forma segura.

La solución fue diseñada bajo principios de desacoplamiento, escalabilidad, resiliencia, seguridad y cumplimiento normativo, considerando la integración con sistemas core existentes, plataformas externas de autenticación y servicios complementarios necesarios para el funcionamiento de una entidad financiera moderna.

El diseño se desarrolla utilizando el enfoque del modelo C4, incluyendo los niveles de contexto, contenedores y componentes, con el fin de presentar la solución desde una perspectiva ejecutiva, funcional y técnica.

Objetivo de la solución

Diseñar una arquitectura tecnológica para una plataforma de banca digital que permita ofrecer servicios financieros de consulta y transaccionalidad de manera segura, disponible, escalable y mantenible.

La solución debe garantizar la integración con los sistemas internos y externos requeridos por el negocio, soportar canales web y móvil, incluir mecanismos modernos de autenticación y autorización, permitir auditoría completa de las operaciones y habilitar una base tecnológica preparada para futuras capacidades funcionales.

Alcance de la propuesta

La arquitectura propuesta contempla los siguientes procesos y capacidades principales:

- Consulta de información del cliente
- Consulta de productos y movimientos
- Transferencias entre cuentas propias
- Transferencias interbancarias
- Notificaciones transaccionales por al menos dos canales
- Onboarding digital con validación biométrica
- Autenticación y autorización basadas en estándares
- Persistencia de clientes frecuentes
- Registro de auditoría de acciones y eventos
- Alta disponibilidad, recuperación ante desastres y monitoreo

Esta propuesta cubre la arquitectura lógica y tecnológica de la solución, incluyendo aplicaciones frontend, servicios backend, integraciones, almacenamiento, mensajería, seguridad y observabilidad.

Enfoque arquitectónico

La solución se plantea mediante una arquitectura desacoplada, basada en microservicios y orientada a eventos, desplegada sobre infraestructura cloud. Este enfoque permite separar responsabilidades por dominio, escalar componentes de forma independiente y reducir el impacto de fallos aislados.

Se propone una capa de entrada controlada por un API Gateway, una capa de servicios de negocio especializada por capacidades funcionales y una capa de integración hacia sistemas internos y externos. Además, se incorpora una arquitectura de mensajería para desacoplar procesos asincrónicos como auditoría y notificaciones.

El objetivo de este enfoque es equilibrar flexibilidad, mantenibilidad, capacidad de crecimiento y cumplimiento de requerimientos no funcionales como seguridad, disponibilidad y rendimiento.

DECISIONES ARQUITECTÓNICAS

Arquitectura de microservicios

Se propone una arquitectura basada en microservicios para separar las capacidades del sistema en dominios funcionales independientes, tales como autenticación, clientes, transacciones, notificaciones, onboarding y auditoría.

Esta decisión permite escalar de manera independiente los servicios con mayor demanda, como transacciones o autenticación, sin afectar al resto de la plataforma. También facilita el mantenimiento, la evolución funcional y la aplicación de principios de responsabilidad única.

Como alternativa se evaluó una arquitectura monolítica; sin embargo, fue descartada debido al mayor acoplamiento entre módulos, la dificultad para escalar partes específicas del sistema y la menor flexibilidad para evolucionar la plataforma a futuro.

Arquitectura orientada a eventos

Se propone el uso de un componente de mensajería para soportar eventos del sistema, particularmente en procesos como envío de notificaciones, auditoría, trazabilidad y tareas asincrónicas derivadas de operaciones transaccionales.

Este enfoque permite desacoplar componentes que no requieren respuesta inmediata al usuario, mejorando la resiliencia del sistema y evitando dependencias síncronas innecesarias. También facilita la Re-ejecución controlada de procesos y la incorporación de nuevos consumidores en el futuro.

Como alternativa se consideró resolver todos los procesos mediante comunicación REST síncrona; sin embargo, esta opción incrementa el acoplamiento, limita la elasticidad y puede afectar el rendimiento general ante picos de carga.

API Gateway como punto de entrada

Se define un API Gateway como punto único de entrada para las aplicaciones cliente. Este componente centraliza funciones como enrutamiento, validación de tokens, rate limiting, observabilidad básica, control de tráfico y aplicación de políticas de seguridad.

Su adopción permite simplificar la exposición de servicios, mejorar el control operacional y establecer una capa homogénea para el acceso desde los distintos canales digitales.

Como alternativa se evaluó exponer directamente los servicios backend; sin embargo, esto incrementaría la complejidad operativa y debilitaría el control centralizado sobre seguridad, trazabilidad y gobernanza de APIs.

Autenticación y autorización basadas en estándares

Se recomienda implementar la autenticación y autorización mediante un proveedor de identidad compatible con OAuth2 y OpenID Connect, evitando construir un mecanismo propietario para este propósito.

Para SPA y aplicación móvil se recomienda el flujo Authorization Code con PKCE, debido a que es el patrón recomendado para clientes públicos y ofrece una mayor protección frente a interceptación de credenciales o tokens.

Esta decisión mejora la seguridad, facilita la incorporación de MFA, biometría y step-up authentication, y reduce el riesgo asociado a implementar lógica crítica de autenticación de manera personalizada.

Aplicación móvil multiplataforma

La arquitectura contempla una aplicación móvil desarrollada sobre un framework multiplataforma. Se evaluaron como opciones principales Flutter y React Native.

Flutter se propone como opción preferente debido a su alto nivel de consistencia visual, buen rendimiento y capacidad para construir interfaces complejas con un solo código base. React Native también es una alternativa válida, especialmente si existe una estrategia fuerte basada en JavaScript o TypeScript dentro de la organización.

La elección final debe alinearse con la estrategia tecnológica del equipo, la experiencia existente y las capacidades de mantenimiento a largo plazo.

Arquitectura general de la solución

La solución se compone de dos canales principales de atención al cliente: una aplicación web tipo SPA y una aplicación móvil multiplataforma. Ambos canales consumen servicios a través de un API Gateway, el cual actúa como punto controlado de entrada a la plataforma.

A nivel backend, la solución se organiza en servicios especializados por dominio. El servicio de autenticación delega la identidad en un proveedor compatible con OAuth2 y OpenID Connect. El servicio de onboarding gestiona altas de nuevos usuarios y validaciones biométricas. Los servicios de clientes y transacciones concentran la lógica de consulta y operación financiera, mientras que los servicios de notificaciones y auditoría atienden responsabilidades transversales fundamentales.

La plataforma se integra con el Core bancario para consultar productos, movimientos y ejecutar determinadas operaciones. Adicionalmente, consume un sistema de información complementaria cuando se requiere enriquecer los datos del cliente. Para la notificación de eventos se consideran al menos dos canales de comunicación externos, como correo electrónico y SMS o push notifications.

La arquitectura se apoya en una base de datos transaccional, una base de auditoría con enfoque append-only, una capa de caché para optimizar lecturas frecuentes y un broker de mensajería que facilita el procesamiento asincrónico y el desacoplamiento entre componentes.

DIAGRAMA 1 – CONTEXTO

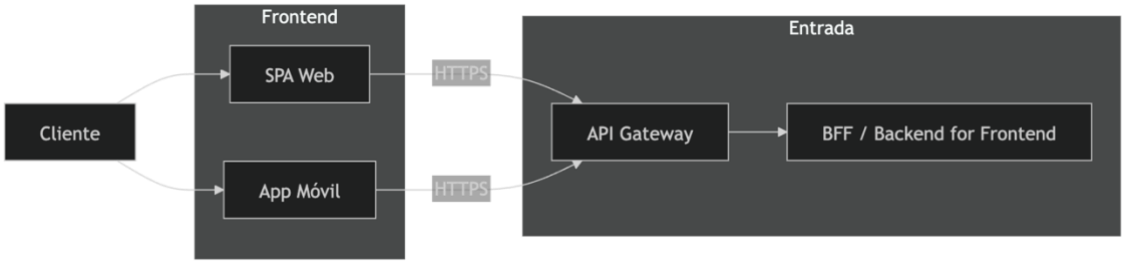
El diagrama de contexto muestra la relación entre la plataforma de banca digital, sus usuarios y los sistemas externos con los que interactúa. Desde una perspectiva de negocio, este nivel permite identificar claramente el alcance del sistema y las dependencias principales sin entrar aún en detalles internos de implementación.

En este nivel se observan los clientes como actores principales, así como el personal de operaciones, seguridad o auditoría que puede requerir trazabilidad o monitoreo. También se muestran los sistemas externos fundamentales: Core bancario, sistema de información complementaria, proveedor de identidad, servicio biométrico, red de transferencias interbancarias y proveedores de notificación.

Este diagrama es relevante porque permite comunicar de forma sencilla la ubicación del sistema dentro del ecosistema corporativo y tecnológico, mostrando qué responsabilidades son propias de la plataforma y cuáles dependen de terceros o de sistemas internos ya existentes.

DIAGRAMA 2 – CONTENEDORES

Vista de Canales y Entrada

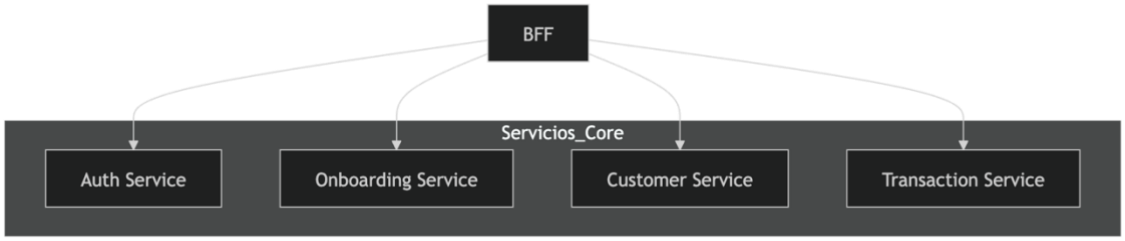


Este diagrama muestra los canales digitales mediante los cuales los usuarios interactúan con la plataforma, así como la capa de entrada encargada de recibir y gestionar las solicitudes.

Se observa que tanto la aplicación web como la aplicación móvil consumen los servicios a través de un API Gateway, el cual actúa como punto de control centralizado para la seguridad, el enrutamiento y la gestión del tráfico.

El uso de un Backend for Frontend (BFF) permite adaptar las respuestas del backend a las necesidades específicas de cada canal, optimizando la experiencia del usuario y reduciendo la complejidad en el frontend.

Vista de Orquestación y Servicios Core



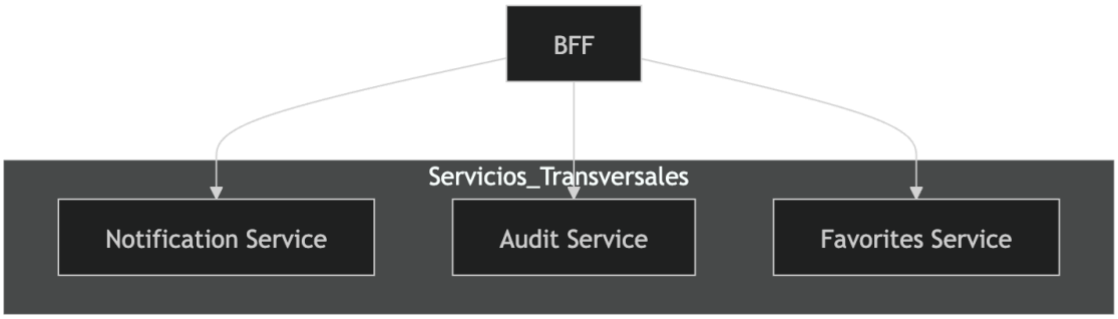
Este diagrama presenta los servicios principales encargados de la lógica de negocio central del sistema.

El servicio de autenticación gestiona la identidad y autorización de los usuarios, mientras que el servicio de onboarding permite el enrolamiento digital mediante validaciones de identidad y biometría.

El servicio de clientes se encarga de la consulta de información relacionada con el usuario, y el servicio de transacciones gestiona operaciones críticas como transferencias, aplicando validaciones de negocio y control de consistencia.

Esta separación permite aislar responsabilidades críticas y escalar de manera independiente los componentes más demandados.

Vista de Servicios Transversales



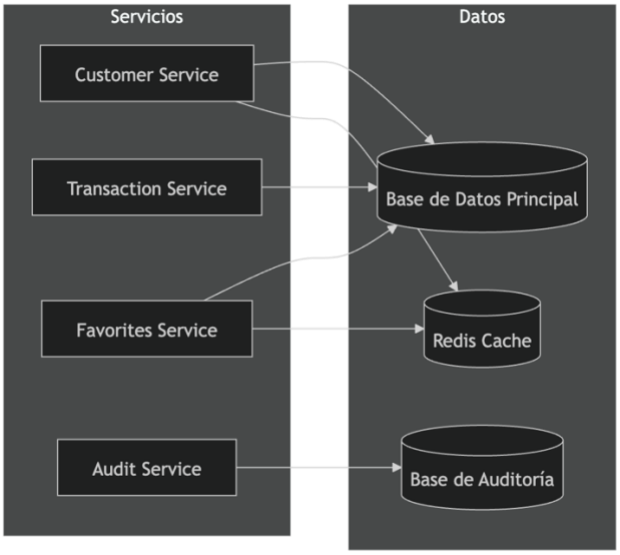
Este diagrama representa los servicios que soportan funcionalidades complementarias dentro de la plataforma.

El servicio de notificaciones se encarga de comunicar eventos relevantes al cliente a través de múltiples canales. El servicio de auditoría registra las acciones y eventos del sistema para garantizar trazabilidad y cumplimiento normativo.

El servicio de clientes frecuentes permite almacenar información reutilizable por el usuario, optimizando procesos como transferencias recurrentes.

Estos servicios están desacoplados de la lógica principal, permitiendo su evolución independiente y reduciendo el impacto sobre el flujo transaccional.

Vista de Integraciones Externas

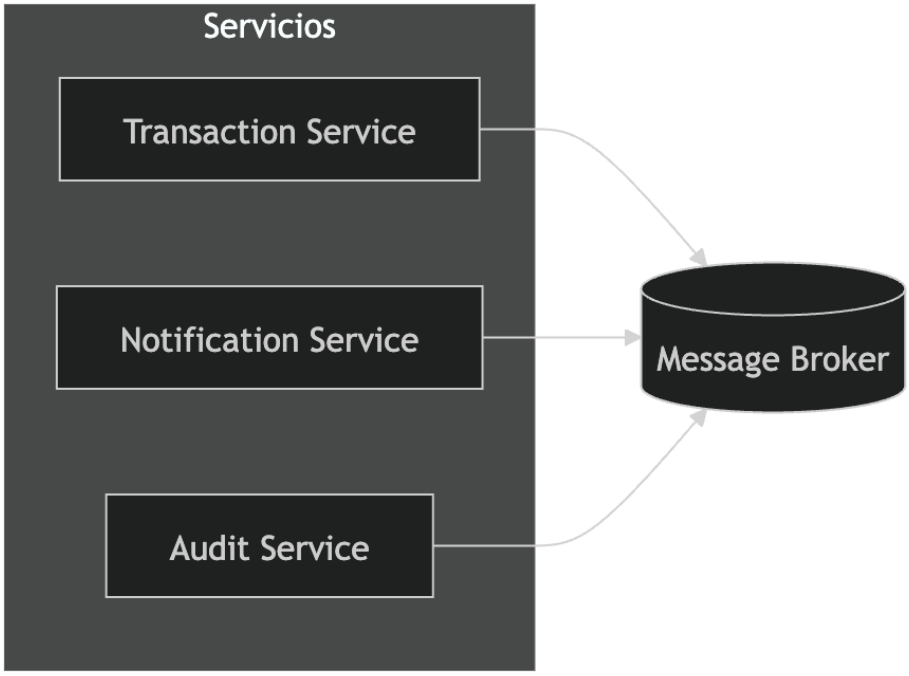


Este diagrama muestra los mecanismos de almacenamiento utilizados por la solución.

La base de datos principal gestiona la información transaccional y operativa del sistema, mientras que la base de auditoría se mantiene separada para garantizar integridad, trazabilidad y cumplimiento regulatorio.

La capa de caché permite optimizar el acceso a datos de alta frecuencia, reduciendo la carga sobre la base de datos principal y mejorando los tiempos de respuesta del sistema.

Vista de Integraciones Externas



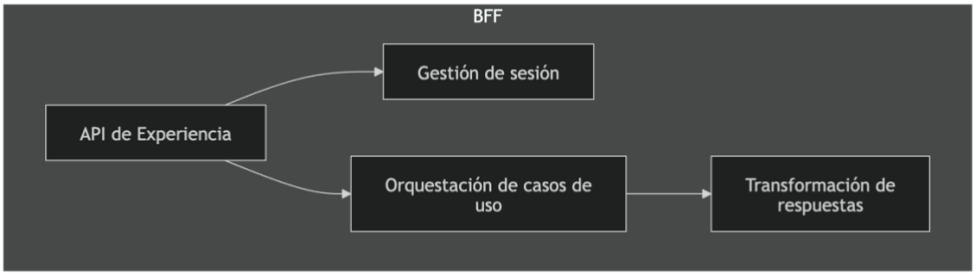
Este diagrama representa la capa de mensajería utilizada para desacoplar procesos asincrónicos dentro del sistema.

El uso de un broker permite manejar eventos como notificaciones y auditoría sin impactar directamente el flujo principal de las transacciones, mejorando la resiliencia y la capacidad de procesamiento del sistema.

Además, este enfoque facilita la incorporación de nuevos consumidores de eventos sin modificar la lógica existente

DIAGRAMA 3 – COMPONENTES

Vista de Capa de Orquestación (BFF)

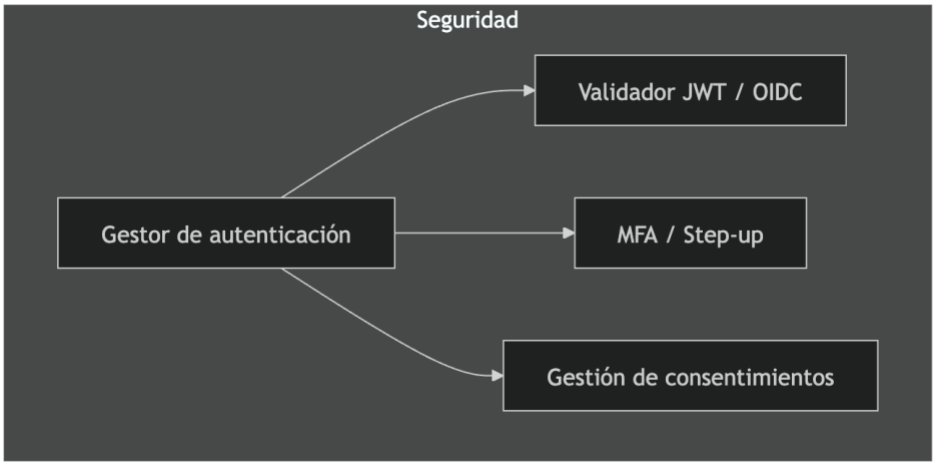


Esta vista muestra la capa de experiencia o Backend for Frontend (BFF), la cual actúa como intermediario entre los canales digitales y los servicios de negocio.

El componente de API expone los endpoints consumidos por las aplicaciones cliente, mientras que la gestión de sesión mantiene el contexto del usuario. La orquestación coordina la ejecución de los distintos servicios según el caso de uso, y el adaptador transforma las respuestas para ajustarlas a las necesidades del frontend.

Esta capa permite desacoplar la lógica de presentación de la lógica de negocio, mejorando la mantenibilidad y la flexibilidad del sistema.

Vista de Autenticación y Seguridad

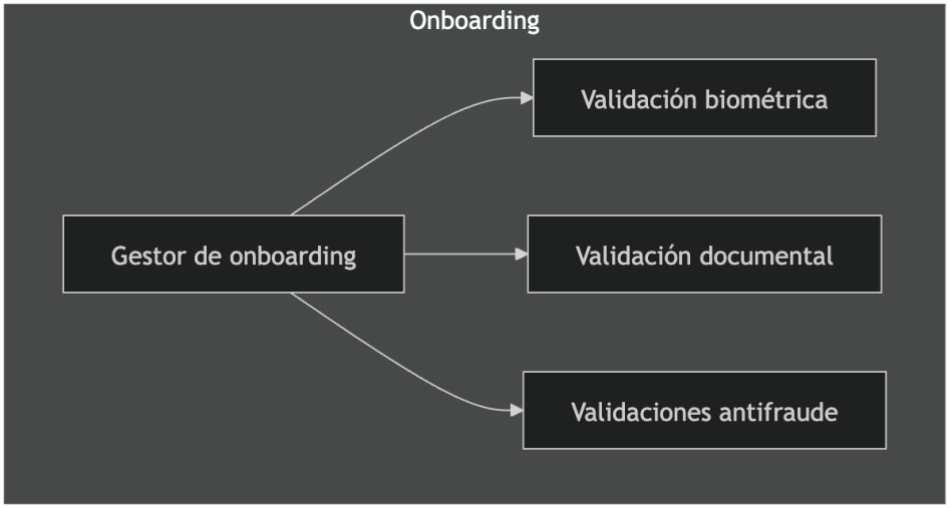


Este diagrama representa los componentes encargados de gestionar la autenticación y autorización dentro del sistema.

El gestor de autenticación delega la validación de identidad en un proveedor externo, mientras que el validador de tokens verifica la integridad y validez de los JWT. El componente de MFA permite reforzar la seguridad en operaciones sensibles, y la gestión de consentimientos asegura el cumplimiento de políticas de acceso.

Esta estructura permite implementar mecanismos de seguridad robustos y alineados con estándares del sector.

Vista de Onboarding Digital

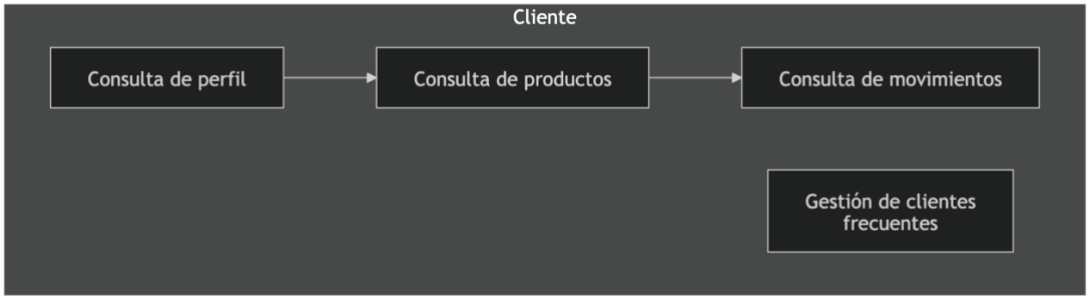


Esta vista muestra los componentes involucrados en el proceso de enrolamiento digital del usuario.

El gestor de onboarding coordina el flujo completo, mientras que los componentes de validación biométrica, documental y antifraude aseguran la identidad del usuario y reducen el riesgo de fraude.

Este enfoque permite construir un proceso de alta seguro, automatizado y alineado con las prácticas modernas del sector financiero.

Vista de Dominio de Cliente

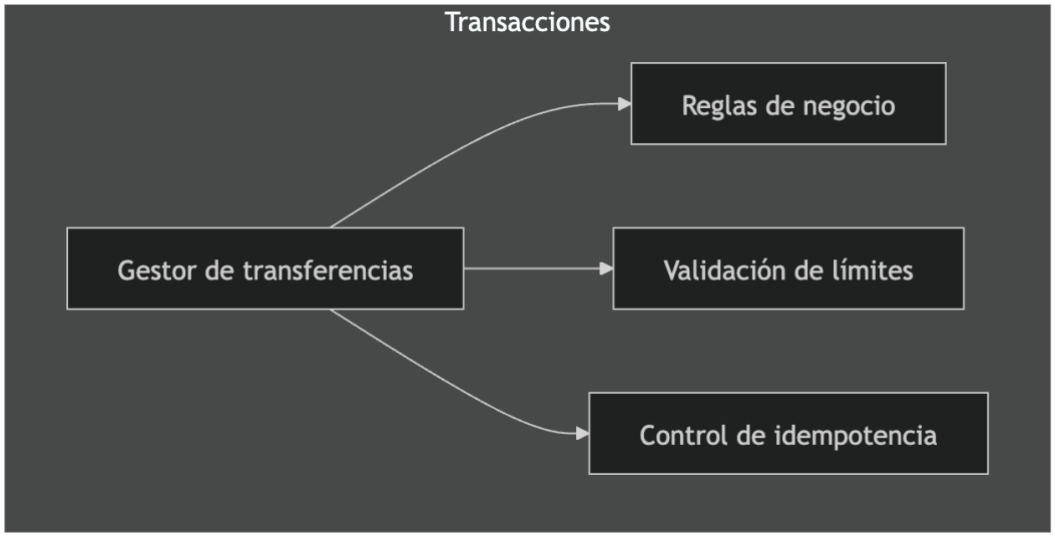


Este diagrama representa los componentes relacionados con la gestión y consulta de información del cliente.

Incluye la consulta del perfil, los productos asociados, los movimientos financieros y la gestión de clientes frecuentes. Estos componentes permiten consolidar la información necesaria para que el usuario tenga visibilidad completa de su estado financiero.

La separación de estos elementos facilita la evolución independiente de cada capacidad.

Vista de Dominio de Transacciones

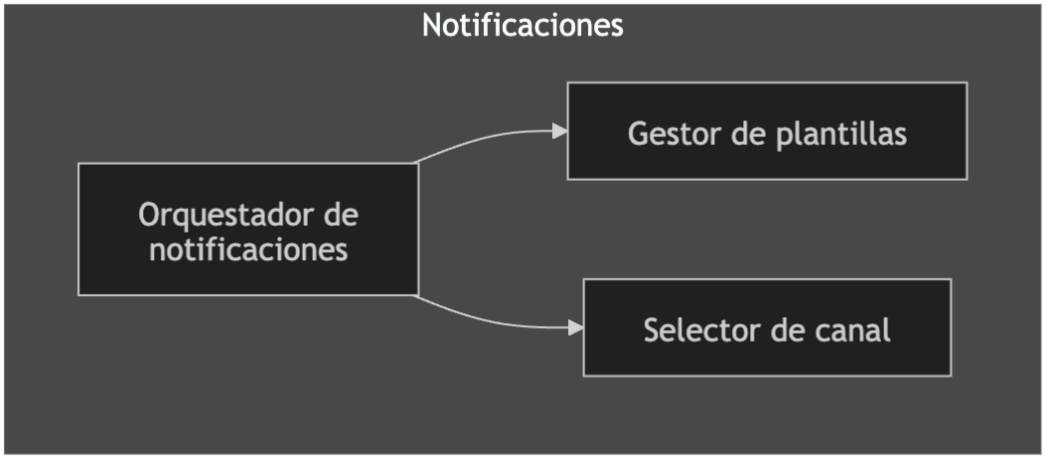


Este diagrama muestra los componentes encargados de la ejecución de operaciones financieras.

El gestor de transferencias coordina el flujo transaccional, apoyándose en componentes especializados para validar reglas de negocio, controlar límites operativos y evitar duplicidad de operaciones mediante mecanismos de idempotencia.

Este diseño permite garantizar consistencia, seguridad y trazabilidad en operaciones críticas del sistema.

Vista de Notificaciones

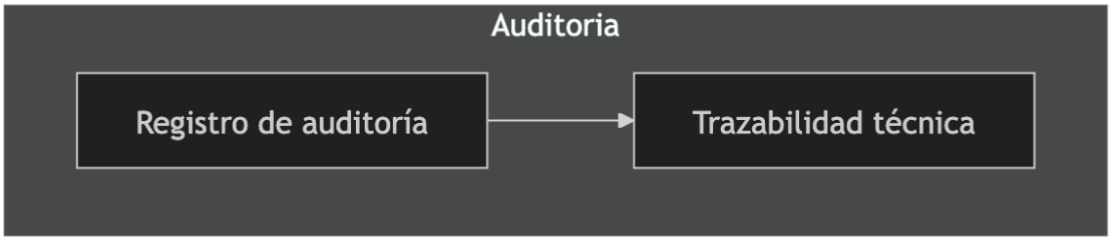


Este diagrama representa los componentes encargados de la comunicación con el usuario.

El orquestador de notificaciones gestiona los eventos que requieren comunicación, el gestor de plantillas define el contenido de los mensajes y el selector de canal determina el medio más adecuado para el envío.

Este enfoque permite flexibilidad en la comunicación y facilita la incorporación de nuevos canales en el futuro.

Vista de Auditoria y Trazabilidad



Este diagrama muestra los componentes encargados de registrar y analizar los eventos del sistema.

El registro de auditoría captura las acciones relevantes desde el punto de vista funcional, mientras que la trazabilidad técnica permite seguir el flujo de ejecución a nivel de sistema.

Estos componentes son esenciales para el cumplimiento normativo, la seguridad y el monitoreo de la plataforma.

Seguridad y autenticación

Dado el contexto financiero de la solución, la seguridad constituye un eje central del diseño arquitectónico. La plataforma se plantea bajo un enfoque de defensa en profundidad, donde se combinan controles en los canales digitales, en la capa de entrada, en la lógica de negocio, en la infraestructura y en la gestión de identidades.

La autenticación se delega a un proveedor de identidad compatible con OAuth2 y OpenID Connect. Para la aplicación web SPA y la aplicación móvil se recomienda el uso de Authorization Code Flow con PKCE, al ser el estándar más apropiado para clientes públicos modernos. Este enfoque evita la exposición directa de credenciales y mejora la protección frente a amenazas comunes.

A nivel operativo, se recomienda complementar el inicio de sesión con mecanismos de autenticación multifactor, especialmente para operaciones sensibles como transferencias, cambios de perfil o enrolamiento de dispositivos. En el caso de onboarding móvil, la validación biométrica se incorpora como parte integral del proceso de alta y verificación de identidad.

Adicionalmente, la solución debe aplicar cifrado en tránsito mediante TLS 1.2 o superior, cifrado en reposo para datos sensibles, gestión segura de secretos, validación de integridad de tokens, rate limiting, protección WAF y controles contra amenazas comunes identificadas en OWASP Top 10.

Onboarding digital

El proceso de onboarding digital se concibe como una capacidad estratégica para habilitar el alta segura de nuevos clientes o la activación de acceso digital. Su diseño debe contemplar validación de identidad, biometría, control antifraude y posterior habilitación de mecanismos de autenticación seguros.

Durante este flujo, la aplicación móvil captura la información del cliente, ejecuta validaciones biométricas y documentales mediante servicios especializados y coordina la creación o habilitación de la identidad digital en el proveedor de autenticación. Una vez completado el proceso, el usuario podrá ingresar mediante credenciales, biometría local del dispositivo o mecanismos complementarios definidos por la organización.

Este diseño permite robustecer la seguridad del enrolamiento, reducir fricción operativa y alinear la experiencia del cliente con las expectativas actuales de servicios financieros digitales.

Gestión de transacciones y reglas de negocio

El dominio transaccional es uno de los componentes más críticos de la plataforma, ya que concentra operaciones sensibles como transferencias entre cuentas propias e interbancarias. Por esta razón, la arquitectura plantea una separación clara entre la experiencia del usuario, la orquestación de la transacción y la ejecución efectiva sobre sistemas internos o externos.

El servicio de transacciones debe incorporar validación de reglas de negocio, control de límites, verificación de autorizaciones, manejo de idempotencia y trazabilidad completa. La idempotencia es especialmente importante para evitar duplicidad de operaciones ante reintentos, timeouts o fallos de red.

Dependiendo del tipo de operación, el servicio puede consumir capacidades del Core bancario o integrarse con una red de transferencias interbancarias. Una vez procesada la transacción, se genera un evento para la notificación al cliente y otro para el registro de auditoría, manteniendo desacopladas estas responsabilidades del flujo transaccional principal.

Auditoría y trazabilidad

La arquitectura incorpora un servicio de auditoría especializado para registrar las acciones relevantes del sistema, tanto desde una perspectiva funcional como técnica. Esto incluye autenticaciones, consultas sensibles, transferencias, cambios de configuración, enrolamiento de dispositivos y eventos relacionados con seguridad.

La persistencia de auditoría debe implementarse sobre un almacenamiento separado del flujo transaccional principal, con preferencia por un esquema append-only que limite modificaciones posteriores y preserve la integridad histórica de los registros.

Esta decisión permite cumplir con requerimientos regulatorios, habilitar revisiones forenses, facilitar procesos de monitoreo y proveer información útil para equipos de seguridad, cumplimiento y operación.

Persistencia de clientes frecuentes

El sistema contempla la existencia de un mecanismo de persistencia para clientes frecuentes o beneficiarios recurrentes. Para esta capacidad se recomienda una aproximación basada en separación entre modelos de lectura y escritura, especialmente si la frecuencia de consulta es alta y el volumen de uso crece con el tiempo.

La información puede almacenarse en un servicio o módulo especializado, apoyado por una base de datos operativa y una capa de caché para acelerar las lecturas más frecuentes. Esta aproximación reduce la carga sobre otros componentes y mejora la experiencia del usuario en escenarios cotidianos de consulta y reutilización de destinatarios.

Integración con sistemas externos

La solución depende de múltiples integraciones externas e internas, por lo que se propone una capa clara de integración controlada por servicios específicos y orquestada desde la lógica de negocio.

El Core bancario constituye la fuente principal de información para productos, cuentas, movimientos y ciertas operaciones financieras. El sistema complementario aporta información ampliada del cliente cuando se requiere mayor nivel de detalle. A esto se suman el proveedor de identidad, el servicio biométrico, la red interbancaria y los proveedores de notificaciones.

Para minimizar el impacto de fallos externos, se recomienda incorporar patrones de resiliencia como timeouts, retries controlados, circuit breakers y fallback strategies donde sea viable. Esta medida reduce el riesgo de fallos en cascada y mejora la estabilidad general del sistema.

Alta disponibilidad, recuperación ante desastres y resiliencia

Debido a la naturaleza crítica del sistema, la arquitectura debe garantizar alta disponibilidad y tolerancia a fallos. Para ello se propone una estrategia de despliegue distribuido en múltiples zonas de disponibilidad, con balanceadores de carga, escalamiento horizontal y redundancia de componentes clave.

La base de datos principal debe contemplar mecanismos de replicación y failover, mientras que la mensajería, la caché y los servicios de aplicación deben desplegarse bajo esquemas redundantes. Asimismo, es necesario incorporar respaldos automáticos, políticas de recuperación y pruebas periódicas de restauración.

Desde la perspectiva de resiliencia, la arquitectura debe incluir circuit breakers, reintentos controlados, colas para procesamiento asincrónico y mecanismos de auto-healing en la capa de infraestructura. Estas prácticas permiten mantener la continuidad operativa incluso ante fallos parciales o degradación temporal de servicios externos.

Monitoreo y observabilidad

La operación de un sistema financiero digital requiere una estrategia robusta de observabilidad que permita detectar incidentes, analizar comportamientos anómalos y medir la salud de la plataforma en tiempo real.

Se recomienda implementar centralización de logs, métricas, trazas distribuidas y alertamiento proactivo. Los indicadores mínimos que observar incluyen latencia de APIs, tasa de errores, volumen transaccional, disponibilidad de servicios, tiempos de respuesta de integraciones externas y comportamiento del broker de mensajería.

Adicionalmente, la observabilidad debe integrarse con capacidades de seguridad y correlación de eventos, de manera que sea posible identificar incidentes operativos y amenazas potenciales de forma temprana.

Consideraciones normativas y de cumplimiento

En una solución orientada al sector financiero es indispensable considerar requerimientos regulatorios y de seguridad aplicables a la protección de la información, trazabilidad, control de acceso y gestión del riesgo.

Entre los elementos normativos y de buenas prácticas que deben considerarse se incluyen la protección de datos personales, el principio de mínimo privilegio, el cifrado de información sensible, la segregación de ambientes, la trazabilidad completa de operaciones, la gestión de vulnerabilidades y la adopción de marcos de referencia como OWASP, PCI DSS y lineamientos de seguridad corporativa aplicables a la entidad.

La arquitectura propuesta incorpora estos principios mediante controles distribuidos en autenticación, autorización, protección perimetral, auditoría, monitoreo, resiliencia y gobierno de datos.

Conclusión

La arquitectura propuesta para la plataforma de banca digital BP responde a los requerimientos funcionales y no funcionales planteados, priorizando seguridad, disponibilidad, escalabilidad, integración y mantenibilidad.

El diseño basado en microservicios, complementado con mensajería, autenticación estandarizada, auditoría especializada y despliegue cloud altamente disponible, permite construir una solución sólida para el contexto financiero actual y preparada para incorporar nuevas capacidades en el futuro.

A través del modelo C4 se logró representar la solución desde distintos niveles de abstracción, facilitando su comprensión tanto para perfiles ejecutivos como para equipos técnicos y operativos.